Arquitectura y operación técnica

Arquitectura y operación técnica

1. Componentes
2. Flujo de una cotización
3. Datos y permisos
4. Mapa de rutas
5. Configuración y secretos
6. Desarrollo y validación
7. Actualizar producción
8. Disponibilidad y costos
9. Respaldo y recuperación
10. Incidentes
11. Referencias de mantenimiento

Arquitectura y operación técnica

Uso interno del operador. Revisión documental: 19 de octubre de 2026, base funcional 44e2561 y periodos 0022. Esta guía organiza los procedimientos existentes; no reemplaza OPERATIONS.md ni acredita que monitoreo/copia externa ya estén configurados.

1. Componentes

Capa	Tecnología / ubicación	Responsabilidad
Interfaz	React 19, TypeScript, Vite; `src/`	Formularios, navegación responsive, vistas y validación de uso
API	Cloudflare Worker; `worker/index.ts` y `worker/routes/`	Autenticación, permisos, vigencia, validación y respuestas
Datos	Cloudflare D1 / SQLite; `migrations/`	Negocios, cuentas, catálogo, clientes, cotizaciones, auditoría y planes
Documentos	jsPDF y AutoTable; `src/lib/quote-pdf.ts`	PDF en el navegador con totales del servidor y marca guardada
Correo de cuenta	Adaptador Resend; `worker/auth/mail.ts`	Verificación, recuperación e invitaciones; no envío de cotizaciones
Verificación pública	Cloudflare Turnstile	Registro/recuperación y desafío de login cuando corresponde
Operación	Wrangler, scripts Node 24 y CI	Migraciones, despliegue, ensayos y comandos de operador

No existe servicio externo de pago por PDF, pasarela de suscripción, facturación fiscal ni integración WhatsApp en el primer lanzamiento. No hay almacenamiento offline de borradores ni caché local del contenido para trabajar sin conexión.

2. Flujo de una cotización

La cuenta autenticada selecciona un negocio del que es integrante. El Worker verifica correo, sesión, permiso y vigencia; valida que cliente/catálogo pertenezcan al negocio. Calcula importes en centavos y guarda número, filas y snapshot de marca en una transacción. La lectura obtiene una vista consistente de encabezado, cliente y partidas. Edición exige revisión; un cambio concurrente produce 409 y conserva el borrador de pantalla.

El PDF usa totales guardados. Marca y modelo se capturan al crear; una nueva marca predeterminada no reescribe las anteriores. Cambiar solo modelo usa revisión del documento y conserva marca/importes. Una actualización explícita de marca reemplaza el snapshot. No se incluyen notas internas en PDF; sí pueden existir en JSON/CSV, por lo que esos archivos son privados.

3. Datos y permisos

Grupos principales de tablas: organizations y memberships; users, sessions y tokens de cuenta; customers; catalog_items; quotes, quote_items y secuencias; plan_activations y subscription_plans; auditorías; invitaciones; MFA maestro; staging/validación de respaldos.

Los IDs técnicos históricos de planes son `gratis` → Plan 1, `pro` → Plan 2 y `negocio` → Plan 3. El nombre técnico `gratis` no indica un plan comercial gratuito. No renombrar IDs en producción para cambiar el precio anunciado.

El panel maestro expone metadatos mediante rutas administrativas, no un selector para abrir negocios ajenos. El operador con D1 puede técnicamente acceder a datos completos; limitar cuentas/procesos y auditar su uso. D1 y snapshots no se presentan como cifrado de extremo a extremo de cada campo. Las contraseñas se almacenan con hashes versionados/salt y pepper; no son texto recuperable ni se «descifran» para soporte.

4. Mapa de rutas

Resumen para localizar código, no una API pública comercial estable. Todas las mutaciones tienen validación/controles adicionales; usar primero la UI y las pruebas existentes.

Familia	Acceso y propósito
`/api/health`	GET público: salud sin datos privados
`/api/auth/*`	Registro, login/logout, correo/recuperación y opciones públicas de seguridad
`/api/businesses`, `/api/businesses/switch`	Negocios del usuario y selección autorizada
`/api/subscription`, `/api/plans`	Vigencia/capacidad; cambios simulados solo en preview local permitido
`/api/branding`, `/api/customers`, `/api/catalog`	Marca, clientes y catálogo del negocio activo
`/api/quotes`, `/api/quotes/:id`, `/duplicate`, `/history`	CRUD con controles, duplicación e historial

Familia	Acceso y propósito
`/api/dashboard`	Resumen y filtros del negocio activo
`/api/team/*`, `/api/invitations/*`	Equipo e invitaciones vinculadas al correo verificado
`/api/backups/*`, `/api/trash*`, `/api/history`	Respaldo/recuperación/historial con permisos de propietario
`/api/security/admin-mfa`, `/api/admin/*`	Segundo factor y administración exclusiva del maestro
`/api/diagnostics`	Metadatos técnicos permitidos; no cuerpos/logos/notas privadas

Las rutas de datos requieren autenticación; las de administración también MFA. Una referencia `X-Request-ID` ayuda a correlacionar fallos sin exponer mensajes internos.

5. Configuración y secretos

Datos de configuración: nombre Worker, binding **DB**, ID real de D1, directorio migrations, URL pública HTTPS, remitente autorizado y site key pública de Turnstile. El archivo versionado contiene ID cero como plantilla: preservar la configuración real del equipo de despliegue.

Secretos por nombre, nunca por valor en esta documentación: `PASSWORD_PEPPER`, `MFA_ENCRYPTION_KEY`, `RESEND_API_KEY`, `TURNSTILE_SECRET_KEY`. Otros controles: `SIGNUP_DAILY_LIMIT` y `MAINTENANCE_READ_ONLY` según operación. `EMAIL_MODE=preview` solo sirve en el entorno local permitido; no habilitarlo como sustituto del correo público.

No regenerar pepper o clave de MFA al actualizar. Los respaldos D1 no contienen esos secretos del Worker; perderlos puede impedir acceso a cuentas restauradas. Custodia separada de secretos y respaldos, gestor seguro y permisos del equipo. No mandar archivos `.dev.vars`, `.env*`, SQL o `.qdb` a soporte abierto o CI.

6. Desarrollo y validación

Desde `quoter`, Node 24.14+ dentro de versión 24:

```
npm ci
npm run db:migrate
npm run dev
```

Preparación inicial de `.dev.vars`, pepper y clave MFA: seguir README.md y los scripts de configuración, preservando claves existentes. No copiar secretos a la terminal del chat.

```
npx playwright install chromium
npm run verify
```

`verify` ejecuta unitarias, lint, tipos/build, 21 suites API/navegador y recuperación. Crea D1/configuración/credenciales ficticias aisladas; no necesita ni prueba el banco, dominio de correo, claves reales o recuperación remota. CI define Ubuntu y Windows; un workflow definido no acredita su ejecución ni configura protección de ramas.

La última evidencia funcional citada está en REMEDIATION.md. La versión con periodos requiere las verificaciones indicadas en REMEDIATION.md. Para cambiar código, repetir las comprobaciones apropiadas.

7. Actualizar producción

1. Revisar commit/configuración y respaldar antes de migraciones.
2. En el equipo autorizado con Wrangler autenticado, actualizar código y dependencias.
3. Aplicar migraciones remotas pendientes; este código requiere hasta **0022_billing_periods.sql**.
4. Ejecutar despliegue y comprobación pública.

```
git pull origin main
npm ci
npx wrangler whoami
npx wrangler d1 migrations apply quoter-db --remote
npm run deploy
npm run check:production -- --url https://quoter.cotizandome.workers.dev
```

Estos comandos son un procedimiento para una actualización autorizada; no fueron ejecutados contra producción al preparar los manuales. Local y remoto son bases independientes. No recrear D1 para resolver un error de autenticación o una migración parcialmente aplicada.

Si aparece 7403, verificar cuenta/permisos con `whoami` y `d1 list`; renovar OAuth si corresponde. Si hay un API token de entorno, puede tener prioridad sobre OAuth: revisar solo su presencia/configuración, nunca mostrar su valor. Conservar bindings y secretos existentes.

8. Disponibilidad y costos

Configurar monitor externo de `/api/health` cada cinco minutos y alerta tras dos fallos consecutivos como propuesta inicial. Probar recepción de alerta. Un 200 de salud no prueba entrega de correo, funcionamiento del banco ni todos los flujos autenticados.

Revisar semanalmente CPU/solicitudes, lecturas/escrituras y tamaño D1, correo por día/mes, almacenamiento de copia externa y facturación del proveedor. Los snapshots de logo pueden dominar espacio. Los cupos activos no controlan todo el almacenamiento conservado. No prometer hosting gratis o servicio ilimitado.

9. Respaldo y recuperación

JSON por negocio: 8 MiB / 2,000 registros, contenido del negocio, sin credenciales/equipo/historial. D1 completa cifrada: contenido de todos los negocios y datos de acceso; exclusiva del operador.

```
npm run backup:key
npm run backup:db -- --remote
npm run backup:drill -- --file ".backups/ARCHIVO-REAL.qdb"
```

`backup:key` conserva la clave existente; no crear una nueva para intentar abrir respaldos anteriores. `backup:drill` descifra e importa en D1 local temporal, verifica y elimina ese estado; no sustituye producción. El fallback parametrizado conserva logos grandes ante límites SQL.

Propuesta de operación: copia diaria y antes de migración; siete diarios y cuatro semanales; copia cifrada externa; ensayo mensual. RPO 24 h/RTO 2 h son objetivos sin SLA medido. Automatización, servicio externo y ensayo publicado siguen pendientes de ejecución según OPERATIONS.md.

El procedimiento de recuperación genera un plan y una D1 nueva, valida esquema y revoca credenciales restauradas; no cambia automáticamente el binding ni reabre el Worker. Seguir OPERATIONS.md para `recovery:plan` / `recovery:apply`, confirmaciones y manejo de claves. No ensayar sobre la D1 vigente ni publicar una copia completa sin revisión.

10. Incidentes

Registrar hora local, versión, categoría/requestId y alcance mínimo. Si puede afectar integridad, usar modo mantenimiento de solo lectura según OPERATIONS.md. Separar fallo de proveedor, autenticación/configuración y error de datos; no volcar cuerpos privados en logs.

Prioridad crítica: acceso de un negocio a otro, pérdida/corrupción de datos o compromiso de credenciales. Alta: registro/recuperación/guardado general bloqueados. Normal: un PDF/formato o consulta individual con alternativa. Son criterios operativos propuestos; no tiempos de respuesta ya contratados.

Reabrir después de una recuperación requiere conciliación y pruebas controladas. Comunicar sin revelar datos ajenos y guardar evidencia privada. No resolver cambios de plan erróneos con SQL improvisado ni regeneración de secretos.

11. Referencias de mantenimiento

Procedimientos canónicos: README.md, PRODUCTION_SETUP.md, OPERATIONS.md, ADMIN_MFA.md, PASSWORD_SECURITY.md, SECURITY_HARDENING.md, ACCEPTANCE.md y REMEDIATION.md, ubicados dos directorios arriba de este archivo. El documento de auditoría es histórico; no tratar sus hallazgos originales como pendientes sin revisar su reparación.

Quoter · Documento del 19 de octubre de 2026. Versión de referencia: base 44e2561 y periodos 0022; decisiones comerciales pendientes de aprobación. Material interno salvo los manuales de cliente destinados a su rol.